PORTFOLIO GRC CYBER

Évaluation du risque cyber fournisseur

SupportCloud Standard | SaaS fictif

Anas El Karkouri
Étudiant ingénieur, 5e année - EMSI Tanger

Version finale 1.2 - 7 octobre 2026

Étude de cas pédagogique : organisations, pièces E/V et décisions simulées. Les annexes décrivent les opérations réelles effectuées sur le laboratoire personnel avec assistance Codex. Aucun test personnel ne clôture une action du cas.

Document de travail. Référentiels ISO étudiés à partir de fiches publiques ; textes complets sous licence non fournis. Aucune certification ni audit formel revendiqué.

Organisation du dossier

1. Projet 2 - Décision proposée et executive summary

2. Projet 2 - Cadrage et criticité du fournisseur SaaS

3. Projet 2 - Dossier fournisseur simulé

4. Projet 2 - Questionnaire, réponses et examen

5. Projet 2 - Constats et registre des risques fournisseur

6. Projet 2 - Remédiation, conditions de production et suivi

7. Revue finale du dossier fournisseur

8. Sources et limites de vérification

Les tableaux larges sont présentés par entrée pour garder chaque champ lisible. Les références de pièces renvoient aux fichiers du portfolio fourni. Les preuves assainies et leurs empreintes sont accessibles dans Annexes_laboratoire.

Source éditable : Projet_2_TPRM/06_decision_et_synthese_EN.md

Projet 2 - Décision proposée et executive summary

SupportCloud - cas pédagogique / formule Standard Version 1.0 - 7 octobre 2026 Dossier simulé ; aucune décision d'une entreprise réelle ni signature réelle.

1. Décision en français

Avis de sécurité proposé

Ne pas autoriser le passage en production en l'état.

Le défaut d'autorisation inter-clients décrit dans V06 est ouvert et n'a pas de retest. Il expose potentiellement les tickets de l'usage cible. Le registre contient **un risque critique et sept risques élevés**, évalués pour cet usage futur avec données clients, et non pour une production déjà déployée.

Le pilote peut continuer dans le scénario uniquement avec ses vingt tickets artificiels, sans données personnelles réelles, documents clients, secrets, connecteurs de production ni dépendance opérationnelle. Cette poursuite limitée ne vaut pas homologation de production.

La décision de pilote est proposée jusqu'au **6 novembre 2026**, soit J+30. À cette date, l'absence de preuves suffisantes impose de réexaminer ou arrêter le pilote, et non de le transformer automatiquement en production.

Motifs déterminants

- **Isolation non démontrée après correction** : défaut inter-clients toujours ouvert, correctif annoncé mais non retesté.
- **Accès privilégiés incomplets** : MFA facultatif sur le tenant Standard et compte support partagé sans MFA imposé.
- **Reprise et investigation insuffisamment étayées** : exercice limité aux fichiers, RPO non démontré, journaux trente jours et solution d'export non validée.
- **Encadrement des données et de la relation incomplet** : tiers support non identifié complètement, délai incident de 72 heures, sortie de 48 heures et export des pièces non démontré.

La certification alléguée n'est pas démontrée pour le service actuel. Cela limite l'assurance disponible, sans constituer une preuve que le fournisseur n'est pas certifié. Même une certification pertinente ne clôturerait pas les défauts spécifiques du dossier.

2. Ce qui permettrait de reconsidérer la production

Les six conditions G1 à G6 du plan de remédiation (05_remediation_suivi.md) doivent être vérifiées :

Condition	Résultat attendu avant décision favorable
G1	Correctif et retest inter-clients pertinents pour le service retenu
G2	Administrateurs client et accès support nominatifs, MFA imposé, exceptions et récupération examinées
G3	Objectifs métier confirmés, reprise complète et récupération client effectivement démontrées
G4	Journaux utiles et protégés sur la durée retenue ; notification et coordination d'incident convenues et exercées

Condition	Résultat attendu avant décision favorable
G5	Tiers, accès, lieux et responsabilités documentés ; revue compétente des engagements et obligations applicables
G6	Export complet utilisable, fenêtre suffisante et fin de traitement encadrée

Les huit cibles de risque seraient alors **deux faibles et six modérées**, sous réserve de réévaluation. Ces valeurs sont des estimations conditionnelles et ne sont pas déjà atteintes.

Une solution compensatoire doit répondre au besoin du client et être testée dans son périmètre. Une autre formule est une nouvelle option à évaluer, pas un traitement déjà réalisé. Les contraintes de prix ou de calendrier ne suffisent pas à accepter un accès inter-clients ouvert sur des données réelles.

3. Fiche de décision renseignée

Champ	Valeur de l'exercice
Objet	Usage du SaaS de tickets SupportCloud Standard
Périmètre évalué	Service et données envisagés ; pièces documentaires simulées
Propriétaire du risque	RS
Avis du dossier	Production défavorable en l'état
Pilote limité proposé	Vingt tickets artificiels, sans connexions de production
Fin de validité proposée du pilote	6 novembre 2026
Risque critique ouvert	S08, score 16 ; miroir R08
Conditions favorables acquises	Aucune condition G satisfaite
Traitements ouverts	VM01 à VM08
Acceptation de risque approuvée	Aucune
Avis juridique réel	Aucun
Autorisation et signature réelles	Aucune
Prochaine décision	Après réception et vérification des preuves ; sinon réexamen à J+30

DG fictive devrait enregistrer son arbitrage dans le scénario. Le présent document fournit une recommandation motivée et ne prétend pas tenir lieu de cette approbation.

4. Executive summary in English

Third-party cybersecurity risk assessment

Provider: SupportCloud, fictional training case **Service:** B2B support ticketing SaaS, Standard plan **Assessment date:** 7 October 2026 **Recommendation:** Do not approve production use under the conditions currently documented.

Purpose and scope

Atlas Services, a fictional company with 40 employees, is considering this SaaS for customer support. The intended production dataset includes professional names, email addresses, ticket content and technical attachments. Customer credentials, health data and identity documents are excluded from the proposed use.

The current pilot contains twenty synthetic tickets. It has no production connectors or operational dependency. This assessment examines the proposed production use through twenty questions and nine simulated provider documents. It is a documentary learning exercise, not an audit of a real provider or an operational security test.

Risk position

The intended service is considered critical because it would hold confidential customer information and support daily operations. Under the documented conditions, the register contains **one critical and seven high risks**. These ratings apply to future production exposure; they are not evidence of a real compromise.

The most significant blocker is an open cross-tenant authorization defect described in the simulated application test summary. A promised fix without a relevant retest does not establish that customers' data is isolated.

The other seven scenarios concern client administrator compromise, shared provider support access, insufficient investigation records, incomplete recovery, inadequately understood third-party access, loss or uncontrolled retention of data at exit, and delayed incident coordination.

Main evidence limitations

Three comparisons are particularly useful:

- The statement that all administrators use MFA conflicts with the Standard tenant configuration and the shared support account. MFA being available is different from MFA being enforced.
- A six-hour file restoration exercise does not demonstrate an eight-hour recovery objective for the full SaaS. Database, indexes and authentication were outside that exercise; the recovery point is also unproven.
- The statement that data remains in Europe does not explain all remote support access or the unidentified external support partner. Storage locations and access locations must be assessed separately.

Additional gaps include thirty-day client log availability, an unvalidated partial export, a proposed 72-hour incident notification period, and a 48-hour post-termination access window. The client's proposed requirements are 90-day useful log availability, initial notification within 24 hours after confirmation of an incident affecting the client, and an adequate recovery window, initially proposed as thirty days.

These durations are requirements designed for this exercise. They are not presented as statutory deadlines or universal ISO/NIST requirements.

The marketing claim of ISO certification is not supported by a current certificate with demonstrated scope and validity in the available dossier. This means the claim is unverified, not that certification does not exist. A suitable certificate could add assurance but would not resolve the service-specific findings.

Required conditions before production

- Correct and retest the cross-tenant authorization defect within the relevant service scope.
- Enforce individual privileged identities and MFA for both the client tenant and provider support, including controlled recovery and emergency access.
- Demonstrate full service recovery against agreed business objectives and prove that customer data can be retrieved and used.
- Provide useful, protected investigation records and agree and exercise incident notification and coordination.
- Complete the access and subprocessor map, establish responsibilities, and obtain a competent review of contractual and applicable data protection requirements.

- Demonstrate complete export and establish workable exit, retention and deletion arrangements.

All eight remediation actions remain open. If their effectiveness is verified, the estimated target position would be **two low and six moderate risks**. Those target ratings are conditional; residual risks have not been reassessed on the basis of verified remediation.

Limited pilot decision

A synthetic-data pilot may continue in the training scenario until **6 November 2026**, subject to the existing restrictions: no real personal data, customer documents, secrets or production connections. If adequate evidence is not available by that date, the client should reassess or stop the pilot.

The limited pilot must not be interpreted as production approval or as acceptance of the critical data isolation risk.

Accountability and monitoring

The support service owner is accountable for the client's risk. Security evaluates evidence, IT verifies tenant and recovery functions, the legal/privacy role reviews the relevant commitments, and management decides whether production can be approved.

If the provider later becomes acceptable, access, security findings, incidents, subprocessors and changes should be reviewed on the proposed quarterly cycle, with a fuller reassessment at least annually in this case. Significant changes or incidents require earlier review.

Decision status: production approval not recommended; remediation and evidence review outstanding. No real approval or contract is represented by this exercise.

5. Présentation orale possible

« J'ai évalué un SaaS fictif pour un usage de support client. J'ai d'abord fixé la criticité et les exigences, puis recoupé vingt réponses avec neuf pièces simulées. J'ai distingué un écart explicite d'un contrôle non démontré. Le défaut inter-clients ouvert bloque la production malgré des réponses favorables sur d'autres sujets. J'ai proposé huit actions, leurs preuves de clôture et une décision limitée au pilote artificiel. »

Cette présentation est fidèle lorsque le dossier est compris et que le caractère simulé est annoncé. Ne pas dire avoir audité un fournisseur réel, négocié un contrat réel, exécuté son pentest ou obtenu ses preuves opérationnelles.

Références

NIST SP 1305 pour la démarche fournisseur ; ISO/IEC 27005:2022 pour les risques SSI. Les critères, scores, exigences et décisions sont propres au cas pédagogique.

Revue de finalisation

07/10/2026 : recoupement intégral (07_revue_documentaire.md), produits et chaînes vérifiés ; aucune nouvelle pièce fournisseur. Recommandation, scores et conditions conservés. Personal lab results do not establish SupportCloud control effectiveness or satisfy any production gate.

Source éditable : Projet_2_TPRM/01_cadrage_criticite.md

Projet 2 - Cadrage et criticité du fournisseur SaaS

Third-Party Cyber Risk Assessment Cas pédagogique simulé - version 1.0 - 7 octobre 2026

1. Service et décision étudiés

Atlas Services envisage d'utiliser SupportCloud - cas pédagogique comme outil SaaS de support B2B. Le contrat envisagé est la **formule Standard**. Les fonctionnalités d'une formule supérieure ne sont pas présumées disponibles.

Le pilote contient vingt tickets artificiels, sans donnée personnelle réelle, pièce client, secret ni connexion aux systèmes de production. La présente évaluation prépare la décision de passer en production ; elle ne constate pas une fuite réelle ou un incident fournisseur réel.

Le service cible serait utilisé par 40 collaborateurs et traiterait des noms, courriels professionnels, textes de support et pièces techniques. Les données de santé, pièces d'identité et secrets d'accès sont interdits par la politique proposée.

2. Périmètre

Examiner le service SaaS et les responsabilités liées aux données : droits client, accès support fournisseur, sécurité applicative, chiffrement, journaux, restauration, sous-traitants, incident, retour et suppression des données.

L'évaluation ne porte ni sur la solidité financière du fournisseur, ni sur ses risques commerciaux généraux. Les effets métier servent uniquement à apprécier les conséquences d'un scénario cyber.

Les systèmes du fournisseur ne sont pas accessibles à l'évaluateur. Les tests intrusifs ne sont pas autorisés. Les preuves opérationnelles proviennent de pièces simulées fournies dans le dossier.

3. Criticité de l'usage cible

La criticité se détermine avant l'examen de maturité du fournisseur. Un fournisseur peut présenter de bons documents tout en restant critique par la nature du service.

Dimension	Situation de l'usage envisagé	Niveau local
Données	Informations clients confidentielles et données personnelles professionnelles	Haut
Disponibilité	Interruption du support si la plateforme devient indisponible ; objectif métier huit heures	Haut
Intégrité	Tickets, affectations et états nécessaires au suivi client	Haut
Privilèges	Administration du tenant et accès support fournisseur ; aucun connecteur de production envisagé	Haut pour les données du tenant
Dépendance	Export et reprise encore à démontrer	Haut
Remplacement	Migration nécessaire, sans solution immédiate équivalente démontrée	Haut

Classe retenue : fournisseur critique pour le support envisagé. Cette classe est un choix local motivé, pas une catégorie obligatoire imposée par NIST.

Le pilote artificiel a une exposition plus limitée. Cela ne réduit pas automatiquement la criticité de l'usage en production.

4. Exigences client retenues pour l'exercice

Exigence	Critère
Authentification	Comptes administrateurs client et fournisseur nominatifs, MFA imposé et récupération contrôlée
Autorisation	Isolation des données entre clients et droits limités au besoin
Assurance applicative	Aucun défaut ouvert permettant un accès non autorisé aux données clients avant production
Reprise	RTO huit heures et RPO 24 heures sur le service complet, à valider avec le métier
Journaux	Événements utiles disponibles 90 jours ou solution équivalente testée et approuvée
Incident	Première notification client sous 24 heures après confirmation d'un incident affectant ses données ou son service
Données et tiers	Localisations, accès support et sous-traitants identifiés et changements notifiés
Sortie	Export complet utilisable et fenêtre de récupération de trente jours proposée
Suppression	Délais distincts pour données actives et sauvegardes, engagements et preuve de fin de traitement
Conformité applicable	Revue compétente des obligations contractuelles et relatives aux données avant production

Les durées ci-dessus sont des besoins contractuels locaux. Elles ne sont pas attribuées à une loi ou à une norme.

5. Responsabilités

Rôle fictif	Responsabilité
RS	Propriétaire du risque fournisseur et du service de support
RSSI	Examine preuves, risques, remédiation et conditions de sécurité
RI	Vérifie droits du tenant, journaux et moyens de reprise client
RJ	Examine contrat, traitement de données et destinations
DG	Autorise la production et les exceptions importantes
SupportCloud	Fournit les pièces, décrit son périmètre et traite ses écarts

Le client garde la responsabilité de ses comptes, données envoyées et usages. Le fournisseur garde celle des composants et opérations relevant de son service. Une matrice de responsabilités doit confirmer les frontières avant signature.

6. Méthode d'examen

Les réponses Q01 à Q20 sont recoupées avec V01 à V09. Un document doit correspondre au bon service, à la bonne formule, au bon tenant ou à la bonne population et à une période pertinente.

Quatre appréciations sont utilisées : documenté pour la conception, partiel, écart confirmé dans le cas, non démontré. Il n'y a pas de moyenne pondérée ni de score global de conformité.

Les risques S01 à S08 utilisent la même échelle V × I que le projet 1. Un manque de preuve diminue l'assurance ; la cotation du risque repose aussi sur un scénario, une exposition et un impact.

7. Lien avec le projet 1

Le risque R08 reprend le scénario fournisseur S08, score actuel estimé 16, comme risque prospectif du passage en production. Les huit risques fournisseur ne sont pas additionnés à R08.

Les autres risques fournisseur sont suivis dans ce dossier. Le registre global pourra être enrichi selon les décisions de périmètre, sans créer deux fois le même événement.

Références

NIST SP 1305, NIST CSF 2.0.

Source éditable : Projet_2_TPRM/02_dossier_fournisseur_simule.md

Projet 2 - Dossier fournisseur simulé

Version 1.0 - 7 octobre 2026 Tous les documents V01 à V09 sont fictifs et créés pour cet exercice.

Ces pièces sont des extraits narratifs et tableaux. Elles ne sont ni des captures réelles, ni des contrats signés, ni des certificats ISO. Les dates sont internes au scénario.

V01 - Fiche de service et données, 1er octobre 2026

Service : SupportCloud. Formule proposée : Standard. Fonction : tickets, comptes, commentaires, pièces jointes et rapports.

Traitements cibles : noms, courriels professionnels, descriptions de demandes et pièces techniques. Les contenus sont fournis par le client. La plateforme ne garantit pas le blocage automatique des secrets déposés dans les tickets.

Localisations déclarées : hébergement principal en Irlande et sauvegardes en France. La fiche commerciale indique « vos données restent dans l'Union européenne ».

La fiche opérationnelle mentionne cependant des collaborateurs support au Maroc et au Portugal, avec accès possible aux tickets lorsqu'une assistance est demandée. L'accès d'un partenaire support externe est également mentionné sans localisation confirmée.

Point d'examen : hébergement, sauvegarde et accès distant doivent être distingués. La phrase commerciale ne couvre pas clairement tous les accès.

V02 - Politique SSI et réponse aux incidents, 15 septembre 2026

La politique déclare TLS pour les échanges, chiffrement des données stockées, procédure de signalement et équipe de réponse.

L'annexe incident prévoit une première information des clients « sous 72 heures après confirmation ». Le dossier ne comporte pas de compte rendu d'exercice coordonné avec un client.

Le document d'architecture décrit la protection des données et une gestion de clés par le fournisseur, mais aucun relevé de configuration ou exercice de récupération de clés n'est fourni.

Point d'examen : le document étaye la conception. Il ne prouve pas toutes les configurations ou l'efficacité des opérations. Le délai de 72 heures diffère du besoin contractuel de 24 heures du cas.

V03 - Identités et accès support, 3 octobre 2026

Population	Configuration décrite
Administrateurs du tenant client	MFA disponible, activation laissée au titulaire, pas d'obligation dans la formule Standard
Lecteurs du tenant	Rôle limité documenté
Administrateurs techniques nominatifs du fournisseur	MFA annoncé
SUPPORT-PARTAGE	Compte utilisé par plusieurs opérateurs, MFA non imposé
Fédération et règles avancées	Présentées pour la formule Enterprise, hors formule Standard évaluée

Le fournisseur déclare dans le questionnaire que « tous les accès administrateurs sont protégés par MFA ». Cette déclaration ne distingue pas le tenant client, les administrateurs techniques et le compte support.

Une revue trimestrielle est annoncée, mais la liste de revue avec décideur et résultat n'est pas fournie.

Point d'examen : disponibilité d'une fonctionnalité et obligation effective sont différentes. Les caractéristiques Enterprise ne sont pas attribuées au contrat Standard.

V04 - Journaux du service, 2 octobre 2026

Événements décrits : connexions, modifications de rôles, accès support et certaines opérations sur les tickets.

Formule Standard : historique client disponible trente jours. Export manuel annoncé pour certains événements. La complétude de l'export, son intégrité, les limites de volume et sa disponibilité après résiliation ne sont pas démontrées.

Conservation 90 jours présentée dans une offre supérieure. Aucune méthode de protection contre la modification des journaux ni liste des droits d'administration des logs n'est fournie.

Point d'examen : un export manuel peut être une piste compensatoire, mais n'est pas considéré équivalent à 90 jours de journaux utiles tant qu'il n'est pas testé, complet et protégé.

V05 - Sauvegarde et exercice de restauration, 4 octobre 2026

Le document indique une sauvegarde quotidienne et une conservation de 90 jours. Sept jobs récents sont indiqués réussis.

Un compte rendu d'exercice du 20 août 2026 indique une restauration de fichiers en six heures. Le périmètre exclut explicitement la base de tickets, les index et l'authentification du service.

Le questionnaire affirme : « Notre reprise en huit heures est démontrée. » Le dossier ne contient pas de restauration du service complet ni de mesure du point de reprise.

Point d'examen : le résultat de six heures sur des fichiers n'établit pas un RTO huit heures pour le SaaS entier. Le RPO 24 heures reste à démontrer.

V06 - Rapport de sécurité applicative, 12 septembre 2026

Le dossier fournit un résumé de test sur le portail et l'API de tickets. L'auteur du résumé est une équipe de test fictive. Aucun véritable prestataire n'est nommé.

Constat de test simulé	Gravité du résumé	État déclaré au 7 octobre
Autorisation inter-clients insuffisante sur une consultation de ticket	Élevée	Ouvert, correctif annoncé, pas de retest
En-tête de sécurité incomplet	Faible	Corrigé selon déclaration, preuve partielle

Les modules d'intégration de la formule Enterprise sont hors du périmètre du rapport. Aucune URL, charge d'exploitation ou cible réelle n'est fournie.

La gravité de ce résumé est distincte du score de risque V × I calculé dans notre étude.

Point d'examen : un défaut d'autorisation ouvert sur les données clients constitue un blocage de production dans les critères du cas. Le rapport ne prouve pas l'absence de toutes les autres vulnérabilités.

V07 - Sous-traitants et accès, 1er octobre 2026

Fonction	Localisation déclarée	Assurance fournie
Hébergement principal	Irlande	Fiche de service
Stockage de sauvegarde	France	Fiche de service
Support interne	Maroc et Portugal	Description opérationnelle
Partenaire support externe	Non confirmée	Identité, localisation et responsabilités incomplètes

La procédure de notification d'un nouveau sous-traitant est mentionnée, mais le délai et le droit d'objection ne figurent pas clairement dans le projet de contrat.

Point d'examen : liste incomplète et cartographie des accès insuffisante. Cela ne démontre pas à soi seul un transfert illicite ; cela empêche une décision éclairée.

V08 - Conditions contractuelles de démonstration, 2 octobre 2026

Projet de contrat, non signé.

- Export de tickets annoncé en CSV depuis l'interface ; export complet des pièces jointes non démontré.
- Accès après résiliation : 48 heures proposées dans la rédaction actuelle.
- Données actives : suppression annoncée sous trente jours.
- Sauvegardes : expiration progressive annoncée sous 90 jours, avec exceptions non détaillées.
- Preuve de suppression : aucun format de compte rendu convenu.
- Notification d'incident : renvoi à la politique interne, sans engagement contractuel de 24 heures.
- Droit d'audit : documents de synthèse seulement ; modalités de demandes complémentaires à préciser.
- Modification des sous-traitants : modalités incomplètes.

Point d'examen : les besoins du client ne sont pas encore contractualisés. Une promesse technique dans une présentation ne vaut pas engagement signé.

V09 - Fiche de vérification d'une allégation ISO, 7 octobre 2026

La page commerciale fictive contient l'allégation « ISO 27001 certified ». Le dossier ne fournit pas de certificat actuel lisible.

Une ancienne fiche d'assurance concerne une activité d'hébergement mutualisé et ne permet pas d'établir que SupportCloud et la formule Standard sont dans le périmètre. Organisme certificateur, dates de validité et portée du service ne sont pas démontrés.

Conclusion : certification actuelle du service non démontrée. Le portfolio ne dit ni que le fournisseur est certifié, ni qu'il ne l'est pas. Il ne fabrique pas de certificat ou de référence d'accréditation.

L'absence de certificat ne prouve pas l'absence de contrôles de sécurité. Elle impose d'examiner les autres pièces et de limiter l'assurance apportée par l'allégation commerciale.

Cohérence volontaire du dossier

Trois rapprochements illustrent les limites d'une réponse déclarative :

- « Tous les administrateurs utilisent le MFA » doit être comparé aux différentes populations de V03.
- « Reprise en huit heures démontrée » doit être comparé au périmètre limité de V05.
- « Données uniquement en Europe » doit être comparé aux accès support et tiers de V01/V07.

Les contradictions sont des données de l'exercice, pas des accusations concernant un fournisseur réel.

Source éditable : Projet_2_TPRM/03_questionnaire_et_reponses.md

Projet 2 - Questionnaire, réponses et examen

Vingt questions renseignées - cas simulé - version 1.0 - 7 octobre 2026

Les réponses ci-dessous appartiennent au fournisseur fictif. L'évaluation porte sur la formule Standard et l'usage cible. « Documenté » ne signifie pas vérification opérationnelle exhaustive.

Questionnaire évalué

ID	Question et preuve attendue	Réponse fictive et pièce reçue	Appréciation de l'évaluateur
Q01	Quel service et quelle formule sont couverts ? Fiche et périmètre contractuel	Service de tickets, formule Standard ; V01	Documenté pour le cadrage. Ne pas retenir les fonctions Enterprise
Q02	Quelles données sont traitées, et quelles limites de contenu ? Cartographie et règles	Noms, courriels, textes et pièces ; pas de filtrage garantissant l'absence de secrets ; V01	Partiel : le client doit maîtriser ce qu'il envoie
Q03	Où sont hébergement, sauvegardes et accès support ? Cartographie complète	« Europe uniquement » ; V01 mentionne Irlande/France et support Maroc/Portugal	Partiel : distinguer stockage et accès distant ; partenaire externe encore inconnu

ID	Question et preuve attendue	Réponse fictive et pièce reçue	Appréciation de l'évaluateur
Q04	Qui sont les sous-traitants et comment les changements sont-ils notifiés ? Liste et procédure	Liste V07, partenaire support incomplet ; délai contractuel imprécis	Non démontré pour la liste complète et les modalités de changement
Q05	Quels rôles client limitent les accès ? Matrice de rôles et test de refus	Rôles lecteur/administrateur décrits ; V03	Conception documentée ; fonctionnement sur un tenant à vérifier
Q06	Le MFA peut-il être imposé aux administrateurs client dans la formule achetée ? Paramétrage et test	MFA disponible mais facultatif en Standard ; V03	Écart au besoin du cas : activation possible ne démontre pas obligation
Q07	Tous les accès privilégiés fournisseur sont-ils nominatifs et protégés ? Population et exceptions	« Tous protégés » ; V03 décrit SUPPORT-PARTAGE sans MFA imposé	Écart confirmé dans le dossier simulé
Q08	Comment arrivées, départs et revues de droits sont-ils tracés ? Échantillon et compte rendu	Revue trimestrielle annoncée ; compte rendu non fourni ; V03	Non démontré. Ne pas conclure que la revue n'existe pas
Q09	Comment les données sont-elles chiffrées et les clés gérées ? Architecture et configuration	TLS et chiffrement stocké décrits ; V02	Documenté pour la conception ; configuration et opérations non démontrées
Q10	Quels journaux sont disponibles et pendant combien de temps ? Échantillon et politique	Trente jours en Standard ; export partiel annoncé ; V04	Écart au besoin de 90 jours, solution compensatoire non validée
Q11	Qui peut modifier les logs et comment sont-ils protégés ? Droits et protection	Aucun relevé précis fourni ; V04	Non démontré, information complémentaire nécessaire
Q12	Les vulnérabilités importantes sont-elles corrigées et retestées ? Registre et retest	Correctif inter-clients annoncé ; constat ouvert ; V06	Écart confirmé, blocage de production
Q13	Quels tests couvrent le service acheté ? Rapport daté, périmètre et limites	Résumé portail/API du 12 septembre ; intégrations exclues ; V06	Partiel : rapport utile, pas assurance exhaustive ni preuve de retest
Q14	Quel RTO/RPO est démontré pour le service complet ? Rapport de restauration	« Huit heures démontrées » ; V05 ne couvre que des fichiers restaurés en six heures	Non démontré pour le service complet et le RPO
Q15	Peut-on récupérer toutes les données à la sortie ? Export de test et fenêtre contractuelle	CSV annoncé, pièces non démontrées, accès 48 heures ; V08	Partiel, avec écart à la fenêtre proposée de trente jours

ID	Question et preuve attendue	Réponse fictive et pièce reçue	Appréciation de l'évaluateur
Q16	Quels délais et preuves de suppression couvrent actif et sauvegardes ? Engagement et attestation	Trente jours actif, 90 jours sauvegardes, exceptions non détaillées ; V08	Partiel : engagements et preuve de fin de traitement à préciser
Q17	Quelle certification ou autre assurance couvre ce service aujourd'hui ? Certificat, portée, dates	Allégation commerciale et fiche ancienne hors portée démontrée ; V09	Certification du service non démontrée ; ne pas la déclarer inexistante
Q18	Quel délai de notification client est engagé ? Politique et clause	72 heures après confirmation ; contrat renvoie à la politique ; V02/V08	Écart au besoin contractuel de 24 heures ; ce besoin n'est pas présenté comme légal
Q19	Le contrat fixe-t-il responsabilités, contrôle et modifications ? Projet complet et validation	Projet non signé, modalités partielles ; V08	Partiel ; examen et négociation nécessaires
Q20	Comment client et fournisseur coordonnent-ils incident et reprise ? Contacts et exercice	Plan fournisseur annoncé, aucun exercice client fourni ; V02	Coordination opérationnelle non démontrée

Relances à adresser dans le scénario

- Fournir la population complète des accès privilégiés, leurs règles MFA et les exceptions, pour la formule Standard.
- Fournir le retest du défaut inter-clients, avec service, version, résultat et limites.
- Démontrer une reprise du service complet, pas uniquement des fichiers.
- Clarifier journalisation, protection et conservation pour la formule retenue.
- Fournir la liste complète des sous-traitants et des accès aux données.
- Proposer les clauses d'incident, sortie, suppression et changement fournisseur.
- Clarifier la portée de l'allégation ISO avec une pièce actuelle, ou documenter les assurances alternatives.

Aucune relance n'a été envoyée à une entreprise réelle.

Principes de décision

Un « oui » au questionnaire ne clôture pas une question lorsque la preuve contredit la réponse, concerne une autre formule ou ne couvre qu'un sous-ensemble.

Les réponses ne sont pas additionnées pour produire un pourcentage de conformité. Une seule faiblesse bloquante peut empêcher la production même si de nombreuses autres réponses sont documentées.

Source éditable : Projet_2_TPRM/04_constats_registre_risques.md

Projet 2 - Constats et registre des risques fournisseur

Cas pédagogique simulé - version 1.0 - 7 octobre 2026 Évaluation de l'usage cible en production, formule Standard.

1. Du justificatif au risque

Les constats F01 à F08 rapprochent une exigence du client et des pièces V01 à V09. Les risques S01 à S08 décrivent un événement cyber et ses conséquences. Un constat documentaire n'est pas, à lui seul, un scénario de risque.

Le fournisseur n'est actuellement utilisé que dans un pilote artificiel. Les scores ci-dessous sont **prospectifs pour la production avec des données clients**, en conservant les conditions décrites au 7 octobre. Ils ne représentent pas le risque actuel d'une production déjà existante.

« Écart » signifie écart au besoin défini pour ce cas. « Non démontré » signifie que la pièce ne permet pas d'établir un résultat. Aucun constat n'est présenté comme une non-conformité de certification ISO.

2. Huit constats documentaires

Lecture du tableau par entrée : tous les champs sont conservés.

Constat : F01 - Authentification du tenant

Critère du cas : Administrateurs client nominatifs et MFA imposé

Pièces et questions : V03 ; Q05/Q06

Analyse motivée : Les rôles sont décrits, mais le MFA reste facultatif en Standard. Écart explicite à l'obligation recherchée ; les fonctions Enterprise ne compensent pas cet écart

Conséquence et traitement : S01 ; VM01 ; vérifier obligation et récupération sur le tenant retenu

Constat : F02 - Accès support fournisseur

Critère du cas : Accès privilégiés nominatifs, MFA et revue traçable

Pièces et questions : V03 ; Q07/Q08

Analyse motivée : SUPPORT-PARTAGE est utilisé par plusieurs opérateurs sans MFA imposé. Cet écart est décrit dans la pièce. La revue trimestrielle est annoncée mais son fonctionnement n'est pas démontré

Conséquence et traitement : S02 ; VM02 ; population complète, suppression du partage et revue documentée

Constat : F03 - Journaux et investigation

Critère du cas : Événements utiles conservés 90 jours et protégés, ou équivalence démontrée

Pièces et questions : V04 ; Q10/Q11

Analyse motivée : L'historique Standard est limité à trente jours. L'export partiel et sa protection ne sont pas démontrés. Écart sur la durée ; incertitude sur complétude, intégrité et accès

Conséquence et traitement : S03 ; VM03 ; obtenir une solution utile à l'investigation et la tester

Constat : F04 - Reprise du service

Critère du cas : RTO huit heures et RPO 24 heures pour le service complet, objectifs métier à confirmer

Pièces et questions : V05/V08 ; Q14/Q15

Analyse motivée : L'exercice de six heures couvre des fichiers, pas la base, les index ou l'authentification. Il ne démontre ni reprise SaaS complète ni RPO. L'export ne constitue pas encore une solution de secours exploitable

Conséquence et traitement : S04 ; VM04 ; restaurer le périmètre complet et vérifier les données récupérables

Constat : F05 - Accès et sous-traitants

Critère du cas : Cartographie complète des lieux et tiers accédant aux données, responsabilités et changements

Pièces et questions : V01/V07 ; Q03/Q04

Analyse motivée : Le support Maroc/Portugal et un partenaire incomplet limitent l'allégation « Europe uniquement ». La cartographie est partielle. Cela n'établit pas un transfert illicite, mais empêche une évaluation éclairée

Conséquence et traitement : S05 ; VM05 ; compléter le dossier et le faire examiner par RJ

Constat : F06 - Sortie et suppression

Critère du cas : Export complet utilisable, trente jours de récupération proposés, suppression maîtrisée

Pièces et questions : V08 ; Q15/Q16

Analyse motivée : Accès 48 heures dans le projet, export des pièces non démontré, exceptions de conservation inconnues. Écart sur la fenêtre ; incertitudes sur export et fin de traitement

Conséquence et traitement : S06 ; VM06 ; contrat de sortie, test d'export et assurance de suppression proportionnée

Constat : F07 - Coordination d'incident

Critère du cas : Première notification sous 24 heures après confirmation d'un incident affectant le client, contacts et coordination

Pièces et questions : V02/V08 ; Q18/Q20

Analyse motivée : La politique prévoit 72 heures. Aucun exercice coordonné n'est fourni. Écart contractuel proposé, pas constat d'infraction à une loi ; coordination non démontrée

Conséquence et traitement : S07 ; VM07 ; clause négociée et exercice de table documenté

Constat : F08 - Isolation inter-clients

Critère du cas : Aucun défaut ouvert permettant un accès non autorisé aux données clients avant production

Pièces et questions : V06 ; Q12/Q13

Analyse motivée : Le défaut d'autorisation demeure ouvert. Un correctif annoncé sans retest ne suffit pas. La portée limitée du rapport interdit une conclusion sur tout le service

Conséquence et traitement : S08 ; VM08 ; correction et retest avant toute donnée réelle

Assurance transversale : allégation ISO

Q17 et V09 ne démontrent pas une certification actuelle couvrant le service. Cette limite doit être portée à la décision et clarifiée. Elle n'est ni un neuvième risque automatique, ni une preuve d'absence de sécurité.

Un certificat valide et pertinent pourrait compléter le dossier. Il ne ferait pas disparaître le défaut ouvert de V06, ne prouverait pas le respect du contrat Standard et ne remplacerait pas les tests ciblés.

3. Convention de cotation

Appliquer la méthode du projet 1 (../Projet_1_SSI/02_methode_registre_risques.md) : vraisemblance V et impact I sur une échelle ordinale de 1 à 5 ; score V × I.

Score	Niveau local
1 à 4	Faible
5 à 9	Modéré
10 à 15	Élevé
16 à 25	Critique

Les indices ne sont pas des probabilités statistiques ni des montants financiers. Les conséquences évaluées restent la confidentialité, l'intégrité, la disponibilité et la capacité à répondre à un incident cyber.

L'horizon est les douze premiers mois d'un éventuel usage en production, selon la convention du projet 1. La vraisemblance reste un jugement motivé et non une fréquence annuelle calculée.

Le risque inhérent représente le scénario avant les mesures considérées. Le risque actuel estimé tient compte des mesures décrites et de leurs limites. Le risque cible suppose un traitement effectivement mis en œuvre et vérifié. **Aucune réévaluation du résiduel fondée sur des preuves de traitement effectif n'est disponible.**

4. Registre renseigné

RS est le propriétaire métier des huit risques. Les pilotes des traitements et les propriétaires des actifs sont distingués dans le plan de remédiation. Le fournisseur traite les composants relevant de sa responsabilité ; il ne décide pas seul de l'acceptation du client.

Lecture du tableau par entrée : tous les champs sont conservés.

ID : S01

Événement cyber et effet sur les actifs : Compromission d'un administrateur du tenant sans MFA imposé ; consultation ou modification de tickets et données A08

Inhérent V/I/score : 4/4/16

Actuel estimé V/I/score : 3/4/12

Niveau actuel : Élevé

Cible conditionnelle V/I/score : 1/4/4

Preuves et traitement : V03, F01, VM01

ID : S02

Événement cyber et effet sur les actifs : Compromission ou usage abusif du compte support partagé ; accès aux données A08 et attribution des actions difficile

Inhérent V/I/score : 4/4/16

Actuel estimé V/I/score : 3/4/12

Niveau actuel : Élevé

Cible conditionnelle V/I/score : 1/4/4

Preuves et traitement : V03, F02, VM02

ID : S03

Événement cyber et effet sur les actifs : Incident détecté tardivement et traces utiles expirées ou incomplètes ; investigation et confinement du tenant A08 retardés

Inhérent V/I/score : 3/4/12

Actuel estimé V/I/score : 3/4/12

Niveau actuel : Élevé

Cible conditionnelle V/I/score : 2/4/8

Preuves et traitement : V04, F03, VM03

ID : S04

Événement cyber et effet sur les actifs : Incident destructif ou altération du service suivis d'une reprise incomplète ; tickets A08 indisponibles ou données non récupérées

Inhérent V/I/score : 3/4/12

Actuel estimé V/I/score : 3/4/12

Niveau actuel : Élevé

Cible conditionnelle V/I/score : 2/4/8

Preuves et traitement : V05/V08, F04, VM04

ID : S05

Événement cyber et effet sur les actifs : Accès aux tickets A08 par un tiers insuffisamment identifié ou encadré ; divulgation non autorisée et difficulté de maîtrise du traitement

Inhérent V/I/score : 3/4/12

Actuel estimé V/I/score : 3/4/12

Niveau actuel : Élevé

Cible conditionnelle V/I/score : 2/4/8

Preuves et traitement : V01/V07, F05, VM05

ID : S06

Événement cyber et effet sur les actifs : Perte ou persistance non maîtrisée de données A08 lors d'une sortie ; export incomplet, accès trop court ou copies encore accessibles

Inhérent V/I/score : 3/4/12

Actuel estimé V/I/score : 3/4/12

Niveau actuel : Élevé

Cible conditionnelle V/I/score : 2/4/8

Preuves et traitement : V08, F06, VM06

ID : S07

Événement cyber et effet sur les actifs : Incident confirmé affectant le client mais notification et coordination tardives ; exposition prolongée et réponse client retardée

Inhérent V/I/score : 3/4/12

Actuel estimé V/I/score : 3/4/12

Niveau actuel : Élevé

Cible conditionnelle V/I/score : 2/4/8

Preuves et traitement : V02/V08, F07, VM07

ID : S08

Événement cyber et effet sur les actifs : Consultation inter-clients non autorisée de tickets A08 via le défaut applicatif ouvert ; divulgation de données confidentielles

Inhérent V/I/score : 4/4/16

Actuel estimé V/I/score : 4/4/16

Niveau actuel : Critique

Cible conditionnelle V/I/score : 2/4/8

Preuves et traitement : V06, F08, VM08 ; miroir de R08

Tous les risques sont **ouverts**. Les scores cibles ne constituent pas des niveaux déjà atteints.

5. Justification des évaluations

S01 - Authentification client

Le rôle lecteur et la séparation annoncée des droits réduisent l'exposition par rapport à l'absence de toute restriction ; une vraisemblance actuelle de 3 est retenue provisoirement. Cette réduction limitée repose sur la conception déclarée, pas sur un essai opérationnel. La confiance est donc moyenne.

Un administrateur compromis conserve un effet potentiel important, I = 4. Le passage cible à V = 1 exige MFA imposé, récupération contrôlée, revue des administrateurs et tests positifs/négatifs. Il ne signifie pas impossibilité d'attaque ou absence de risque de session.

S02 - Compte support

Les comptes techniques nominatifs sont décrits comme protégés, mais le compte partagé demeure une voie d'accès. La protection d'une partie de la population justifie une réduction limitée de 4 à 3 ; le MFA universel n'est pas présumé. Confiance moyenne sur la population, élevée sur l'écart explicitement décrit dans V03.

La cible V = 1 exige suppression du compte partagé, comptes individuels, authentification renforcée, restriction des accès support et traces nominatives vérifiées. L'impact reste 4.

S03 - Traces et investigation

Le scénario associe incident cyber et besoin d'historique au-delà de trente jours. Les journaux annoncés ont une utilité partielle mais n'établissent pas une investigation complète. V = 3 est un jugement pédagogique lié à cet usage, pas une conséquence automatique de la durée.

L'impact 4 correspond à une réponse compromise sur des données clients. La cible V = 2 suppose collecte utile, protection et conservation vérifiées ; aucune automatisation d'export n'est créée dans ce projet.

S04 - Reprise

Un job réussi et un exercice limité aux fichiers ne prouvent pas la reprise de l'application. L'efficacité de reprise n'est donc pas retenue comme réduction du score dans ce cas. Cela ne veut pas dire qu'aucune sauvegarde n'existe.

V = 3 décrit la possibilité d'un incident destructif sur le service critique ; I = 4 décrit l'interruption et la perte de tickets envisagées. La confiance dans le RTO/RPO est faible. La cible V = 2 porte sur la probabilité du scénario composé « incident puis reprise insuffisante », à réévaluer après exercice complet.

S05 - Tiers et données

L'existence d'accès support et d'un partenaire non identifié crée une exposition à examiner. Le manque d'identité, de localisation et de responsabilités diminue l'assurance ; il n'établit ni abus réel ni violation de droit.

V = 3 et I = 4 sont retenus pour un accès à des données confidentielles en production. Confiance moyenne sur l'exposition, faible sur l'encadrement. Une cartographie seule ne réduit pas le risque : la cible exige aussi vérification des droits, restrictions, responsabilités et changements.

S06 - Fin de relation

Les 48 heures contractuelles et l'absence d'export des pièces démontré rendent plausible une sortie incomplète. Une copie persistante reste un scénario de confidentialité, pas une fuite observée.

V = 3 et I = 4 reflètent dépendance et sensibilité du service. La cible suppose un export exploitable testé, une fenêtre suffisante convenue et une suppression encadrée avec preuve adaptée. Une promesse d'attestation n'est pas une preuve reçue.

S07 - Incident fournisseur

Le fournisseur annonce un plan, mais le délai proposé de 72 heures peut retarder les mesures client. Le besoin de 24 heures est local et reste à négocier. L'absence d'exercice fourni n'établit pas l'absence de tout entraînement fournisseur.

Le scénario de délai de réponse retient V = 3 et I = 4. La cible V = 2 exige clause acceptée, contacts disponibles et exercice coordonné. Une clause seule ne démontre pas le comportement réel.

S08 - Isolation des clients

V06 décrit une faiblesse ouverte donnant accès à un autre client dans le scénario. V = 4 est motivé par une voie d'accès concrète, I = 4 par les données confidentielles exposables. Aucun taux d'exploitation, volume d'incident ou score CVSS n'est inventé.

La cible V = 2 suppose correction et retest couvrant les droits et tenants concernés. Le retest serait une preuve ciblée ; il n'établirait pas l'absence de toute autre vulnérabilité. **Sans cette preuve, le risque reste 16 et la production reste bloquée.**

6. Lecture consolidée

L'usage cible comporte **un risque critique et sept risques élevés** dans le dossier actuel. Les cibles comporteraient **deux risques faibles et six risques modérés**, si tous les traitements sont mis en œuvre et vérifiés.

Les risques peuvent se recouper : S01/S02/S08 affectent les mêmes données, S03/S07 influencent la réponse. Les scores ne sont ni additionnés ni convertis en une probabilité globale de compromission.

Le registre du projet 1 reprend S08 sous R08 : score actuel 16, cible 8. Il s'agit du même scénario vu au niveau de la PME. Ne pas compter deux fois cet événement.

7. Réévaluation et acceptation

Chaque nouvelle pièce doit préciser sa date, la formule, le périmètre, la population et les limites. L'évaluateur vérifie sa pertinence, RS réévalue le scénario, DG décide selon les conditions de production.

Le défaut inter-clients n'est pas accepté pour une production avec données réelles. Un traitement seulement prévu n'autorise pas l'utilisation du score cible.

État du dossier : décision de production défavorable en l'état ; remédiation ouverte ; aucune acceptation signée.

Références

ISO/IEC 27005:2022 pour la gestion des risques SSI ; NIST SP 1305 pour la démarche fournisseur. La méthode de cotation et les jugements du registre sont propres à l'exercice.

Source éditable : Projet_2_TPRM/05_remediation_suivi.md

Projet 2 - Remédiation, conditions de production et suivi

Cas simulé - version 1.0 - 7 octobre 2026 Toutes les actions sont proposées et ouvertes. Aucun engagement fournisseur n'est réellement obtenu.

1. Principes de traitement

RS reste propriétaire du risque cyber du service. RI vérifie les fonctions du tenant, RSSI examine l'assurance et RJ examine les clauses et obligations applicables. SupportCloud réalise les changements sur son service. DG autorise éventuellement la production.

J correspond au 7 octobre. Les délais sont des **objectifs du client dans le scénario**, en jours calendaires. Ils ne constituent pas des promesses du fournisseur. Si une échéance ne peut pas être tenue, le service reste hors production et le client réexamine la solution.

2. Plan de remédiation renseigné

Lecture du tableau par entrée : tous les champs sont conservés.

Action : VM01

Risque et constat : S01/F01

Traitement demandé : Comptes administrateurs individuels, MFA imposé pour la formule retenue, récupération et sessions maîtrisées

Pilote client / intervenant fournisseur : RI / responsable IAM fournisseur

Cible proposée : J+15, 22 octobre ; avant production

Preuve attendue et vérification : Matrice complète des administrateurs, règles effectives et essais d'authentification positive/négative sur tenant d'essai. Une fiche Enterprise seule est rejetée

État : Ouverte

Action : VM02

Risque et constat : S02/F02

Traitement demandé : Retirer SUPPORT-PARTAGE, encadrer accès support temporaires, revue et journalisation nominative

Pilote client / intervenant fournisseur : RSSI / responsable opérations fournisseur

Cible proposée : J+15, 22 octobre ; avant production

Preuve attendue et vérification : Liste de population privilégiée, retrait du compte partagé, MFA et revue avec décideur. RSSI examine les exceptions et les accès d'urgence

État : Ouverte

Action : VM03

Risque et constat : S03/F03

Traitement demandé : Couvrir les événements utiles sur 90 jours, protéger les traces et limiter les droits ; préciser la solution Standard ou une autre formule

Pilote client / intervenant fournisseur : RI / responsable service et logs fournisseur

Cible proposée : J+30, 6 novembre ; avant production

Preuve attendue et vérification : Échantillon représentatif, conservation configurée, accès/protection et récupération d'événements vérifiés. L'export manuel partiel ne clôture pas l'action

État : Ouverte

Action : VM04

Risque et constat : S04/F04

Traitement demandé : Démontrer reprise du service complet et point de reprise, puis une voie de récupération client exploitable

Pilote client / intervenant fournisseur : RI et RS / responsable continuité fournisseur

Cible proposée : J+30, 6 novembre ; avant production

Preuve attendue et vérification : Rapport avec début/fin, composants, données restaurées, contrôles d'intégrité, dépendances, RTO/RPO observés et limites. RS confirme les objectifs métier

État : Ouverte

Action : VM05

Risque et constat : S05/F05

Traitement demandé : Compléter tiers/localisations/accès, responsabilités, exigences de sécurité et modalités de changement

Pilote client / intervenant fournisseur : RJ et RSSI / responsable données et contrats fournisseur

Cible proposée : J+15, 22 octobre ; avant production

Preuve attendue et vérification : Cartographie et liste complètes, restrictions d'accès, contrat pertinent et revue compétente documentée. Aucun avis juridique favorable n'est présumé

État : Ouverte

Action : VM06

Risque et constat : S06/F06

Traitement demandé : Négocier fenêtre de récupération, export complet, restitution, suppression et exceptions de sauvegarde

Pilote client / intervenant fournisseur : RS et RJ / responsable service fournisseur

Cible proposée : J+30, 6 novembre ; avant production

Preuve attendue et vérification : Export de tickets ET pièces testé, réutilisation démontrée, clause de fenêtre suffisante et délais distincts de suppression. Assurance adaptée de fin de traitement prévue

État : Ouverte

Action : VM07

Risque et constat : S07/F07

Traitement demandé : Convenir notification initiale sous 24 heures après confirmation d'un incident affectant le client ; contacts, escalade et exercice commun

Pilote client / intervenant fournisseur : RSSI et RJ / responsable incidents fournisseur

Cible proposée : Clause J+15 ; exercice J+30, 6 novembre ; avant production

Preuve attendue et vérification : Clause acceptée, contacts et scénario de table avec chronologie, décisions et écarts. Pas de notification réelle ni d'attaque dans l'exercice

État : Ouverte

Action : VM08

Risque et constat : S08/F08

Traitement demandé : Corriger le défaut d'autorisation inter-clients et faire retester le périmètre affecté

Pilote client / intervenant fournisseur : RSSI / responsable développement et test fournisseur

Cible proposée : Plan J+2, 9 octobre ; correction et retest visés J+10, 17 octobre ; avant production

Preuve attendue et vérification : Preuve du correctif, version, tests de refus entre tenants, vérification des voies concernées et limites du retest. Aucun test intrusif client non autorisé

État : Ouverte

L'estimation de coût et la faisabilité restent à recueillir. Changer de formule ou de fournisseur impose de réexaminer périmètre, pièces, contrat et risques ; aucune fonction supplémentaire n'est considérée acquise.

Clarification complémentaire de Q17

Demander une pièce d'assurance actuelle avec portée et dates, ou une explication documentée de l'allégation commerciale. La traiter comme assurance complémentaire. Ne pas remplacer les preuves VM01 à VM08 par un certificat, et ne pas inventer de certificat pour remplir le dossier.

3. Six conditions bloquantes avant production

Condition	Vérifications nécessaires	État au 7 octobre
G1 - Isolation des clients	VM08 : défaut corrigé et retest pertinent, aucun défaut équivalent ouvert dans le périmètre retenu	NON SATISFAITE
G2 - Accès privilégiés	VM01/VM02 : comptes nominatifs, MFA imposé et récupération encadrée, tenant et support couverts	NON SATISFAITE
G3 - Reprise et récupération	VM04 : objectifs métier validés, service complet repris et données récupérables avec mesures observées	NON DÉMONTRÉE
G4 - Investigation et incident	VM03/VM07 : traces utiles et protégées, conservation retenue, clause et coordination d'incident	NON SATISFAITE
G5 - Données et tiers	VM05 : cartographie, sécurité des accès, engagements et revue compétente avant production	NON DÉMONTRÉE
G6 - Sortie et suppression	VM06 : export exploitable, fenêtre adaptée et engagements de suppression vérifiés au niveau pertinent	NON SATISFAITE

Une condition n'est satisfaite qu'après examen de **tous** ses éléments. Une réponse « oui » à une question du formulaire ne suffit pas. La clarification de l'allégation ISO complète l'assurance mais ne remplace aucune de ces conditions.

Le niveau de preuve de suppression avant production peut être une procédure démontrée, une assurance de contrôle pertinente et un engagement contractuel précis. La preuve de suppression de **nos propres données** sera collectée après une sortie effective ; on ne peut pas l'exiger comme un fait déjà réalisé avant la première utilisation.

4. Extraits de clauses à négocier

Ces propositions sont des exigences client pédagogiques à faire examiner par RJ. Elles ne sont pas des clauses juridiquement validées ni un contrat prêt à signer.

Authentification et responsabilité

Le périmètre contractuel identifie la formule et les fonctions de sécurité disponibles. Les administrateurs client et les opérateurs fournisseur accédant aux données disposent d'identités individuelles et d'une authentification renforcée obligatoire. Les accès d'urgence font l'objet de règles d'activation, durée, traçabilité et revue. Les responsabilités de paramétrage du tenant et d'exploitation fournisseur sont explicites.

Incident

Le besoin du client est une première information sous 24 heures après confirmation d'un incident affectant ses données ou le service convenu. Cette première information contient les éléments connus, l'état des incertitudes, un contact et le prochain point de suivi. Les parties définissent aussi le signalement rapide d'une suspicion pertinente, sans attendre artificiellement une certitude totale. Aucune obligation légale n'est déduite de cette durée contractuelle locale.

Reprise et journaux

Les objectifs RTO/RPO et les composants couverts sont fixés après validation métier. Les preuves d'exercice indiquent mesure, périmètre et limites. Les événements utiles, accès aux traces, durée de disponibilité, protection et moyens d'investigation sont définis pour la formule souscrite.

Données, tiers et sortie

Les lieux de stockage et d'accès, les catégories de tiers et leurs responsabilités sont documentés. Les changements donnent lieu à une information permettant une réévaluation et à des modalités d'objection ou de sortie convenues.

Le retour porte sur tickets, commentaires, pièces et métadonnées nécessaires à une reprise. La fenêtre de trente jours est une proposition à valider contre les besoins et moyens du client. Le contrat distingue suppression des données actives, expiration des sauvegardes, restrictions pendant cette période, exceptions motivées et preuve de fin de traitement.

5. Registre de suivi des conditions

Ce tableau est une photographie du dossier. Les champs non remplis sont réellement non obtenus, pas implicitement favorables.

Étape	Situation documentée
Relance des pièces	Liste de demandes rédigée ; aucun envoi réel
Accord du fournisseur	Aucun engagement réel
Réception de nouvelles preuves	Aucune nouvelle pièce réelle
Examen technique	Non réalisé sur un service réel
Réévaluation des scores	Cibles estimées ; résiduels non réévalués après traitement effectif
Approbation de production	Non accordée dans la décision proposée
Acceptation signée	Aucune

Une clôture doit enregistrer identifiant VM, pièce et version, vérificateur, date, population testée, résultat, limites, nouvelle cotation et approbateur. Si une pièce est rejetée, inscrire la raison et la prochaine demande. Conserver la version précédente.

6. Suivi si le fournisseur devient admissible

Le calendrier proposé dépend de sa criticité :

- Revue des accès et des exceptions du client chaque trimestre ; assurance fournisseur pertinente demandée à la même cadence.

- Suivi trimestriel des incidents, vulnérabilités ouvertes importantes, changements de tiers et conditions contractuelles.
- Réévaluation complète au moins annuelle dans le scénario, et avant renouvellement majeur.
- Réévaluation immédiate après incident affectant le client, nouveau défaut important, nouveau sous-traitant, changement de lieu, modification de formule, perte d'une fonction de sécurité ou assurance devenue périmée.
- Revue de sortie avant résiliation, avec export de contrôle et plan de conservation/suppression.

Ces fréquences sont des choix locaux. Elles ne sont pas des obligations universelles fixées par NIST.

Indicateurs proposés

Indicateur	État actuel du dossier	Cible
Conditions G1 à G6 satisfaites	0 sur 6	6 sur 6 avant production
Actions VM clôturées avec preuve	0 sur 8	8 sur 8, puis surveillance
Défauts ouverts donnant accès inter-clients	1 dans le résumé simulé	0 dans le périmètre retenu et retesté
Reprise du service complet démontrée	Non	Objectifs convenus atteints et limites acceptées
Liste complète des tiers et accès	Non démontrée	Pièce actuelle examinée

Ne pas convertir ces indicateurs en un pourcentage de « conformité ISO » ou de sécurité du fournisseur.

7. Repères NIST CSF 2.0 - GV.SC

Sélection pédagogique de huit sous-catégories, avec thèmes reformulés et applications propres au cas. Ce tableau n'est pas une évaluation de toute la catégorie GV.SC.

Repère	Thème de travail	Trace dans ce projet
GV.SC-01	Organisation de la démarche fournisseur	Cadrage, méthode, conditions et calendrier proposés
GV.SC-02	Responsabilités internes et externes	RS, RSSI, RI, RJ, DG et interlocuteurs fournisseur
GV.SC-04	Identification et priorisation des fournisseurs	Criticité de l'usage support cible
GV.SC-05	Exigences intégrées aux accords	Critères client et clauses à négocier
GV.SC-06	Examen avant engagement	Questionnaire et recoupement des pièces avant production
GV.SC-07	Risques fournisseur suivis au cours de la relation	Registre S01 à S08, actions et événements de réévaluation
GV.SC-08	Coordination des incidents avec les fournisseurs	VM07, contacts et exercice de table proposés
GV.SC-10	Fin de relation préparée	VM06, retour et suppression des données

Le NIST SP 1305 guide l'utilisation du CSF pour les risques de la chaîne d'approvisionnement. Les identifiants sont issus du CSF 2.0. Les documents créés ici décrivent un exercice et des cibles ; ils ne prouvent pas l'exécution d'un programme fournisseur réel.

Source éditable : Projet_2_TPRM/07_revue_documentaire.md

Revue finale du dossier fournisseur

Version 1.1 - 07/10/2026 ; données de référence fictives inchangées au 7 octobre 2026.

Conclusion

Les vingt réponses ont été rapprochées des neuf pièces ; huit chaînes F/S/VM correspondent aux six conditions G. La recommandation défavorable à la production reste justifiée. Aucune nouvelle preuve fournisseur réelle n'a été obtenue. Les tests personnels ne lèvent aucune condition G.

Recoupement de chaque question

Question	Pièces examinées	Chaîne ou sujet	Appréciation conservée
Q01	V01	cadrage	Documenté pour le cadrage. Ne pas retenir les fonctions Enterprise
Q02	V01	usage et minimisation	Partiel : le client doit maîtriser ce qu'il envoie
Q03	V01,V07	F05/S05/VM05/G5	Partiel : distinguer stockage et accès distant ; partenaire externe encore inconnu
Q04	V07	F05/S05/VM05/G5	Non démontré pour la liste complète et les modalités de changement
Q05	V03	F01/S01/VM01/G2	Conception documentée ; fonctionnement sur un tenant à vérifier
Q06	V03	F01/S01/VM01/G2	Écart au besoin du cas : activation possible ne démontre pas obligation
Q07	V03	F02/S02/VM02/G2	Écart confirmé dans le dossier simulé
Q08	V03	F02/S02/VM02/G2	Non démontré. Ne pas conclure que la revue n'existe pas
Q09	V02	assurance de chiffrement transversale	Documenté pour la conception ; configuration et opérations non démontrées

Question	Pièces examinées	Chaîne ou sujet	Appréciation conservée
Q10	V04	F03/S03/VM03/G4	Écart au besoin de 90 jours, solution compensatoire non validée
Q11	V04	F03/S03/VM03/G4	Non démontré, information complémentaire nécessaire
Q12	V06	F08/S08/VM08/G1	Écart confirmé, blocage de production
Q13	V06	F08/S08/VM08/G1	Partiel : rapport utile, pas assurance exhaustive ni preuve de retest
Q14	V05,V08	F04/S04/VM04/G3	Non démontré pour le service complet et le RPO
Q15	V08	F04/F06/S04/S06/VM04/VM06/G3/G6	Partiel, avec écart à la fenêtre proposée de trente jours
Q16	V08	F06/S06/VM06/G6	Partiel : engagements et preuve de fin de traitement à préciser
Q17	V09	assurance ISO transversale non demontree	Certification du service non démontrée ; ne pas la déclarer inexistante
Q18	V02,V08	F07/S07/VM07/G4	Écart au besoin contractuel de 24 heures ; ce besoin n'est pas présenté comme légal
Q19	V08	cadre contractuel transversal G4/G5/G6	Partiel ; examen et négociation nécessaires
Q20	V02	F07/S07/VM07/G4	Coordination opérationnelle non démontrée

Vérification des produits et des niveaux

24 produits S inhérent/actuel/cible recalculés et huit niveaux actuels contrôlés ; aucun écart. S01/S02 : actuel 3×4=12, cible 1×4=4. S03 à S07 : actuel 3×4=12, cible 2×4=8. S08 : actuel 4×4=16, cible 2×4=8. Un critique/sept élevés actuellement pour l’usage cible ; deux faibles/six modérés conditionnels. Le miroir R08/S08 n’est pas additionné.

Contradictions et portée des preuves

- MFA : V03 contredit le « tous protégés » ; Standard facultatif et SUPPORT-PARTAGE sans obligation. Cela établit un écart décrit ; Q08, sans rapport de revue, reste non démontré.
- Reprise : V05 exclut base, index et authentification. Six heures de fichiers ne prouvent ni RTO du SaaS entier ni RPO. Des sauvegardes sont déclarées ; leur absence n’est pas conclue.
- Localisations : Irlande/France pour stockage, Maroc/Portugal pour accès support et partenaire inconnu V07. Cartographie insuffisante, sans conclusion de transfert illicite.

- Standard/Enterprise : fédération avancée, durée de journaux supérieure et intégrations Enterprise ne sont pas attribuées à Standard. Une migration est une option à réévaluer.
- V09 : certification alléguée non démontrée pour le service, organisme et validité ; jamais déclarée inexistante.
- Q09 : conception de chiffrement décrite, configuration et opérations non démontrées. Q02 reste un besoin de minimisation client, pas un neuvième risque artificiel.
- Délais : 24 h incident, 90 jours logs, 30 jours de récupération, échéances et revues sont des exigences locales proposées. Aucun faux délai légal ni prescription ISO universelle.
- Version anglaise : même périmètre Standard, vingt tickets artificiels, un critique/sept élevés, conditions ouvertes, pilote proposé jusqu'au 6 novembre 2026 ; cibles conditionnelles concordantes.

Trace automatisée et examen qualitatif

VERIFICATION_DOCUMENTAIRE.json (../Annexes_laboratoire/preuves/INVENTAIRE/VERIFICATION_DOCUMENTAIRE.json) conserve 109 contrôles pour les deux projets. Ils vérifient produits, niveaux actuels, références Q, correspondances F/S/VM et miroir. La pertinence, les contradictions, les limites et la décision ont été relues qualitativement en complément ; une présence de référence ne constitue pas une preuve d'efficacité.

Scores et décision inchangés : aucune erreur de cotation trouvée. Actions VM01 à VM08 et conditions G1 à G6 restent ouvertes/non satisfaites ou non démontrées selon leur état initial.

Source éditable : SOURCES.md

Sources et limites de vérification

Version 1.0 - 7 octobre 2026

Sources officielles

Référence	Source primaire	Utilisation dans le portfolio
SRC01	ISO/IEC 27001:2022	Référence des exigences de SMSI ; distinction entre étude de cas et certification
SRC02	ISO/IEC 27002:2022	Guide de mesures de sécurité ; les mesures retenues répondent aux risques du cas
SRC03	ISO/IEC 27005:2022	Référence de gestion des risques SSI ; notre échelle et nos seuils sont des choix locaux
SRC04	ISO/IEC 27001:2022/Amd 1:2024	Existence de l'amendement relatif au climat
SRC05	Communiqué conjoint ISO/IAF, février 2024	Prise en compte du climat dans l'analyse du contexte et des parties intéressées
SRC06	NIST CSF 2.0, CSWP 29	Vérification des identifiants de sous-catégories utilisés dans les deux projets
SRC07	NIST Organizational Profiles	Comparaison actuel/cible et suivi des écarts
SRC08	NIST SP 1305, guide C-SCRM	Lien entre diligence fournisseur, criticité, exigences et suivi
SRC09	CNDP : transfert de données à l'étranger	Point de vérification du projet d'hébergement et de support à l'étranger
SRC10	BSI : présentation de la révision ISO/IEC 27002	Recoupement public de références de mesures ; support informatif, pas remplacement de la norme

Les résumés du portfolio sont rédigés pour le cas. Les textes normatifs complets ne sont pas reproduits.

Ce qui est vérifié et ce qui reste à vérifier

Les fiches officielles ISO confirment les éditions utilisées et le rôle des trois normes. Les pages et publications NIST consultées confirment les sous-catégories sélectionnées. Le communiqué ISO/IAF documente l'ajout des considérations climatiques.

SRC10 a été identifié dans les résultats publics pour recouper certains repères. Son contenu intégral n'a pas été contrôlé ; il n'est pas utilisé pour affirmer une vérification exhaustive des vingt mesures.

L'intégralité des normes ISO sous licence n'a pas été fournie. Les correspondances de clauses et de mesures sont des repères de travail, avec libellés reformulés. Avant un audit professionnel, un examen de certification ou une déclaration de conformité, relire les textes autorisés et vérifier le référentiel applicable.

La sélection de vingt mesures dans l'extrait de SoA n'est pas une revue complète de l'annexe A. Aucune mesure omise de cet extrait n'est déclarée non applicable.

Le profil NIST est volontairement limité à treize sous-catégories. Il ne constitue pas une couverture de tout le CSF. Aucune note de maturité inventée n'est attribuée au NIST.

Le projet fournisseur utilise en complément huit sous-catégories GV.SC, sans prétendre évaluer toute cette catégorie. Les correspondances ISO et NIST décrivent des rapprochements de travail, pas une certification de couverture.

L'analyse CNDP est limitée au signalement d'un point à examiner : finalités, catégories de données, destinations, accès à distance et formalités applicables. Une certification ISO, un contrat ou une localisation européenne ne démontrent pas à eux seuls la licéité d'un transfert. Aucun dossier CNDP ni avis juridique réel n'a été établi.

Sources internes de l'exercice

Source	Nature	Portée
Contexte Atlas Services	Hypothèse créée pour l'exercice	Effectifs, activités, actifs, contraintes et besoins
E01 à E10	Documents fictifs écrits pour l'atelier	Conclusions documentaires du projet 1
V01 à V09	Documents et déclarations fictifs	Conclusions documentaires du projet 2
Rapport de stage Tanger Med fourni par Anas	Document utilisateur réel	Observation historique H01 exclusivement

Le document réel est « rapport stage.pdf », fourni par Anas. Les sections pertinentes décrivent le périmètre du laboratoire, les essais contrôlés, les faux positifs, la répartition du travail et les limites du prototype.

Aucun certificat, signature, logo de certification, numéro d'accréditation ou preuve fournisseur réelle n'a été fabriqué. V09 est une fiche narrative de vérification d'allégation, pas un faux certificat ISO.

Choix de méthode propres au cas

Les éléments suivants sont des conventions pédagogiques, et non des prescriptions ISO ou NIST : douze risques internes, vingt questions fournisseur, huit risques fournisseur, vingt mesures dans l'extrait de SoA, quatre tests manuels, cotation 1 à 5, seuils d'acceptation, exigences MFA, durées de conservation et délais de remédiation.

Le délai de notification fournisseur de 24 heures est une exigence contractuelle proposée dans l'exercice. Ce document ne le présente pas comme un délai légal marocain.

Sources techniques et nouvelle revue du 07/10/2026

- Keycloak 26.8 OpenJDK, administration et TLS : composant réel, OTP, rôles et sessions ; seules les fonctions testées sont revendiquées.
- Release Keycloak et Temurin 25 : téléchargements officiels ; empreintes attendues et observées dans T01-P01.
- Wazuh Windows log collection, image VM et Microsoft 4625 : source, réception et alerte T02 prouvées ; conservation longue durée non démontrée.
- Python zipfile et Git git-show : mécanismes locaux T03/T04.

Les fiches publiques ISO 27001/27002/27005, CSF 2.0 et SP 1305 ont été revues. Les textes ISO complets restent non fournis ; cette revue ne prétend pas vérifier exhaustivement toutes leurs exigences. Les preuves techniques se trouvent dans la matrice (Annexes_laboratoire/MATRICE_PREUVES.md), séparées de E/V et H01.

- Installation Wazuh manager, journaux et archives, options internes, Ubuntu officiel daté et manuel VirtualBox 7.1 : préparation/diagnostic T02. Paramètres observés séparés d'une preuve de conservation durable.